

1. Databaser

- a. Kraftiga lösenord (längden och salt) bcryptjs(bcrypt)
- b. Hantera tillgång till data efter behov
- c. Kryptera all data som lagras

2. Brute Force Attacks

- a. Använda bcrypt
- b. Rate-Limiting

3. XSS (Cross Site Scripting) Attacker

- a. Cookies endast med httpOnly(JWT)
- b. Tvätta inmatningsdata(Sanitize)
- c. Addera speciella HTTP Header attribut

4. DDOS

- a. Rate Limiting
- b. Begränsa storleken på paket som vi tillåter

5. NOSQL och SQL injection

- a. mongoose för MongoDB, SchemaTypes
- b. PRISM SchemaType för MySQL, Sqlite, PostgreSQL
- c. .NET EntityFramework
- d. ALDRIG tillåta dynamiska frågor (select * from ? where ? = !)

6. Övrigt

- a. Alltid använda HTTPS!!!
- b. Inte tillåta att JWT som har gått ut på datum att användas igen
- c. ALDRIG skicka detaljerad felinformation till klienten via stack trace
- d. Parameter pollution
`http://localhost:5001/api/v1/vehicles?sort=mileage&sort=modelYear`
- e. `http://localhost:5001/api/v1/vehicles?sort=mileage&sort=<script>do something bad</script>`